

Enterprise GRC Program Charter

Governance Model, Unified Control Catalog, and 18-Month Roadmap

SecurityGroup101 | Enterprise GRC Program

Prepared By: Maxine Jones, GRC Analyst | Reviewed By: Chief Information Security Officer

Version 1.0 | Classification: Confidential – Internal Use

1. Governance Model

The governance model is based on COBIT 2019 and ISO 38500 and defines how SecurityGroup101 directs, manages, and monitors information and technology to support secure and compliant fintech operations. It is built around six principles: responsibility (clear assignment of roles and accountability), strategy (alignment of IT and security with business goals), acquisition (risk-informed technology investment), performance (measurement through defined metrics), conformance (compliance with laws and policy), and human behavior (culture, training, and change management).

Role	Responsibility
Board of Directors	Approves risk appetite and strategic security initiatives; receives regular GRC reporting
Executive Leadership (CIO/CISO/CTO)	Owns the enterprise security and GRC programs; ensures alignment with business strategy
GRC Team	Conducts risk assessments and compliance activities; maintains the control catalog and framework crosswalks
Security Operations	Monitors threats and security events; responds to incidents and manages tooling
IT Operations and Engineering	Implements and maintains technical controls; ensures secure configuration and patching
Business Owners	Own risks and controls within their domains; participate in risk assessments and remediation

Risk decisions are escalated based on impact, likelihood, and regulatory exposure, with a formal risk acceptance process for residual risk and a Security Steering Committee serving as the primary governance forum.

2. Unified Control Catalog

The control catalog harmonizes requirements across NIST CSF, ISO 27001, COBIT 2019, GLBA, PCI DSS, and FFIEC into a single set of controls, tracked using four status definitions: Implemented (fully deployed and operational), Partial (implemented but incomplete or inconsistent), Draft (defined but not yet implemented), and Gap (not implemented).

Control ID	Control Name	Status
AC-01	Access Control Policy	Draft
AC-02	Strong Authentication (MFA)	Partial
AC-03	Least Privilege	Partial
DS-01	Data-at-Rest Protection	Partial
DS-02	Data-in-Transit Protection	Implemented
DS-03	Data Loss Prevention	Gap
IP-01	Patch Management	Partial
IP-02	Vulnerability Management	Partial
DE-01	Security Monitoring	Partial
RS-01	Incident Response Plan	Draft
RC-01	Lessons Learned	Gap
RE-01	Disaster Recovery	Implemented
RE-02	Business Continuity	Partial

Core identity and access controls (MFA, least privilege) are not yet fully enforced; data protection controls are partially implemented; monitoring and detection capabilities require expansion; and incident response and continuous-improvement processes are not yet fully mature. These gaps are tracked through the roadmap below and reflected in the Statement of Applicability.

3. 18-Month GRC Roadmap

Phase	Timeline	Key Activities
Phase 1 – Assessment	Months 0–2	Enterprise-wide GRC maturity assessment, asset inventory validation, NIST SP 800-30 risk assessment, regulatory mapping, identification of high-risk gaps
Phase 2 – Build	Months 2–7	Formalize governance model and roles, develop and approve core policies, build the unified control catalog, develop DRP/BCP, define KPI/KRI reporting
Phase 3 – Implementation	Months 7–14	Implement/enhance MFA, RBAC, encryption, and centralized logging; expand SIEM coverage; establish vulnerability management SLAs; implement vendor risk management program; initial DRP/BCP testing
Phase 4 – Monitor & Improve	Months 14–18	Track KPIs/KRIs, conduct internal audits and control effectiveness assessments, perform annual risk reassessment, update policies and roadmap based on lessons learned

The program is currently positioned within Phase 1–2 of this roadmap: foundational governance, policy, and control-catalog work is underway, while several Phase 3 activities — most notably the formal vendor risk management program — have already been initiated ahead of schedule.

4. Why This Program Matters

This governance model, control catalog, and roadmap give SecurityGroup101 a single, auditable source of truth for security posture: who owns what, what's actually implemented versus drafted versus gapped, and the sequence in which remaining work will close. That structure is what lets the organization speak credibly to regulators, auditors, and partner financial institutions about where it stands today rather than where it eventually intends to be.